Title: **Access Control Leading to Unauthorized Admin Panel Access**

Broken Access control enforces policy such that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification or destruction of all data, or performing a business function outside the user's limits.

Reproduction Steps:

1.visit https://0aef009004958ada80947bc200c000b5.web-security-academy.net/

2.**Perform directory brute-forcing using a tool such as Dirb to discover hidden endpoints:**

EX)dirb https://0aef009004958ada80947bc200c000b5.web-security-academy.net/

```
$dirb https://0aef009004958ada80947bc200c000b5.web-security-academy.net/

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Thu Feb 19 05:48:24 2026
URL_BASE: https://0aef009004958ada80947bc200c000b5.web-security-academy.net/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: https://0aef009004958ada80947bc200c000b5.web-security-academy.net/ ----
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/analytics (CODE:200|SIZE:0)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/favicon.ico (CODE:200|SIZE:15406)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/filter (CODE:200|SIZE:13713)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/login (CODE:200|SIZE:6265)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/Login (CODE:200|SIZE:6265)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/logout (CODE:302|SIZE:0)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/my-account (CODE:302|SIZE:0)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/product (CODE:400|SIZE:30)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/robots.txt (CODE:200|SIZE:45)
```

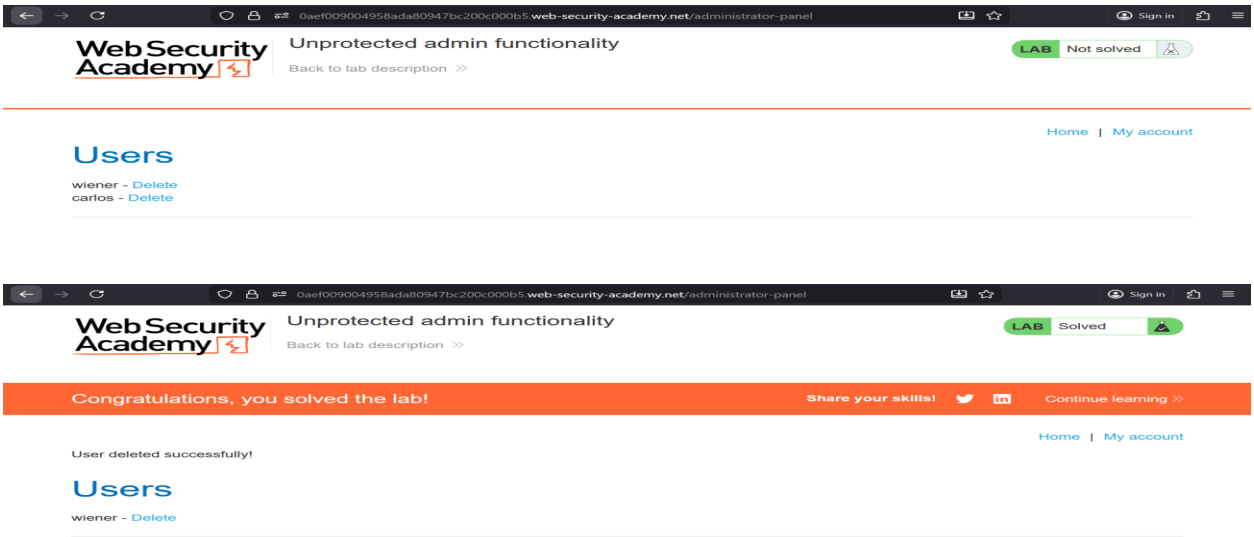
3. **During enumeration an admin-related endpoint can be identified from the text and put it in the URL then you will access to the Admin panel**

4. By accessing the admin endpoint directly via the URL, the attacker gains unauthorized access to the admin panel.

5. From the admin panel, the attacker can delete the user "carlos".

Proof of Concept (PoC):

```
┌─[mohamed@parrot]─[~]
└──╼ $dirb https://0aef009004958ada80947bc200c000b5.web-security-academy.net/

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Thu Feb 19 05:48:24 2026
URL_BASE: https://0aef009004958ada80947bc200c000b5.web-security-academy.net/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: https://0aef009004958ada80947bc200c000b5.web-security-academy.net/ ----
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/analytics (CODE:200|SIZE:0)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/favicon.ico (CODE:200|SIZE:15406)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/filter (CODE:200|SIZE:13713)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/login (CODE:200|SIZE:6265)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/Login (CODE:200|SIZE:6265)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/logout (CODE:302|SIZE:0)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/my-account (CODE:302|SIZE:0)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/product (CODE:400|SIZE:30)
+ https://0aef009004958ada80947bc200c000b5.web-security-academy.net/robots.txt (CODE:200|SIZE:45)
```

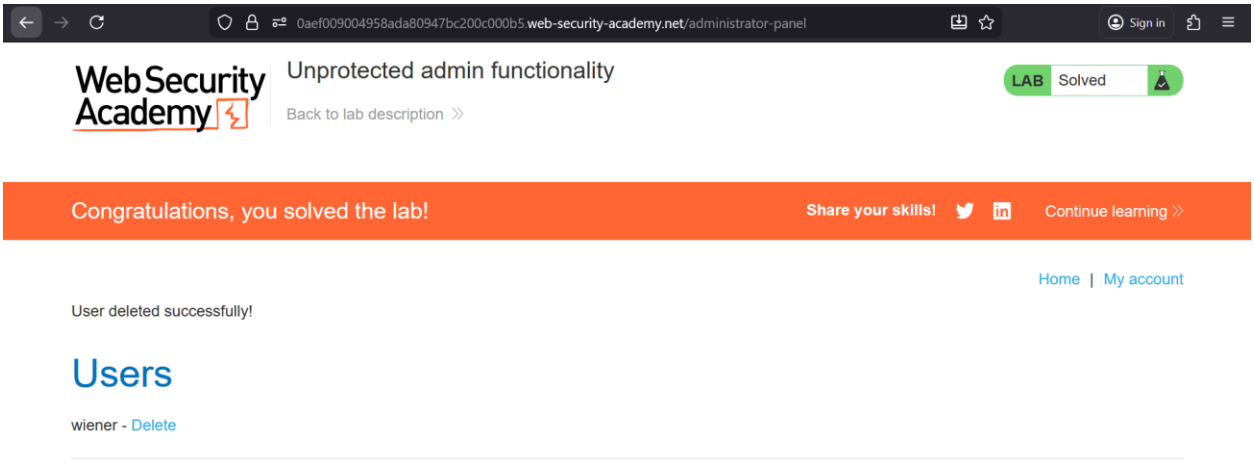


Impact statement:

This vulnerability allows an unauthenticated attacker to access the admin panel.

An attacker can perform administrative actions such as deleting users, modifying data, or disrupting the application functionality.

If exploited in a real-world system, this could lead to privilege escalation, data loss, and full compromise of administrative functionality.



Mitigation :

1.Deny by Default: Assume all access is forbidden and explicitly grant access only to those authorized, enforced on the server-side.

2.Least Privilege: Grant every user the minimum level of permissions they absolutely need to perform their function.

3.Don't Trust the Client: All access control decisions must be made and enforced on the server, not by hiding buttons in the UI.

4.Verify Ownership (IDOR): Ensure every database query verifies that the record belongs to the authenticated user (e.g., WHERE user_id = ?).

5.Log and Monitor: Log every failed access attempt and monitor for unusual patterns to detect